ISS-exam-01/02/2021

---

(1) Explain what is the principle "defense-in-depth", why it is needed in ICT systems and make a concrete example of its implementation.

- **Explain:** "Defense-in-depth" means that you should have not only one defense line, but you should put multiple defense line in cascade (in series, one after the other).
- **Why:** it is needed because if you have one single security control, then the problem is that this security control may fail (for a bug, for a misconfiguration, for an attack). So you should not rely on a single line of defense.
- **Example:** To place one firewall that should block the traffic, but then you don't trust the firewall and so, you put behind that an IDS, to detect if some kind of traffic was allowed to pass through firewall even if it should not.

---

(2) A user must decide if to protect a file with a mac or with a digital signature, for each case describe the operations to be performed, the security properties obtained, and the relative advantages and disadvantages.

- **MAC:**
  - Operations: A MAC is computed through the keyed digest. So you compute an hash not only over the data but also over a shared key (e.g. HMAC).
  - Security Properties Obtained: Data authentication and data integrity.
  - Advantages: It is a fast solution.
  - Disadvantages: You don't get non-repudiation e you need for manage and distribute the shared key.
- **Digital Signature:**
  - Operations: It is computed in the following steps:

    1) You compute the hash of the document;

    2) Then, you encrypt the hash with the private key of the signer.
  - Security Properties Obtained: Data authentication and data integrity and no-repudiation.
  - Advantages: You get non repudiation and there is no key distribution.
  - Disadvantages: It is slow and complex because it is using asymmetric cryptography. And then, in order to get no-repudiation, you also need some kind of trust in the public key. So, either you have some mechanism for direct trust, or you are using an associated public key certificate.

(3) Explain what is an asymmetric challenge-response authentication system, describe which data are exchanged between the client and the server, and discuss the advantages and disadvantages of this approach.

- **Explain and data exchanged:**
  1. The client to be authenticated sends its public key certificate to the server.
  2. The server creates a challenge, by encrypting with the public key of the client, a random nonce.
  3. The client uses its private key to decrypt the challenge and sending it back in clear.
  4. Finally, the server will check if the response matches to the nonce that it created.
- **Advantages:** This kind of algorithm is the most strong kind of authentication that we can get. It's immune to sniffing and replay.
- **Disadvantages:** It's computationally heavy, because it requires asymmetric encryption. And it requires good trust on the certificate with PKI or something equivalent. And most of all there is the big risk of an unwanted signature by the client (if the nonce is an hash of a document instead of a random nonce).

---

(4)Describe the HTTP basic authentication and discuss its advantages and disadvantages.

- **Describe:** In http basic authentication, at the opening http connection, the server is requesting that the user is sending username and password, encoded in base64.
- **Advantages:** It is quite simple and supported by any web server, because it uses just username and password. It is User friendly.
- **Disadvantages:** It is based on username and password. You can sniff and understand, through decoding, the meaning of the traffic exchanged because b64 it is just an encoding technique, but not an encryption. Also without perform decoding you can do a reply attack, because the answer to the question is always the same.

---

(5) Consider some network traffic protected with IPsec (V2) ESP in transport mode and tell which security properties would the traffic have. For each property, tell if it is compulsory or optional, how it would be obtained, and which part of the ip packet it would protect.

- **Security properties:** The security properties offered to this traffic are:
  - Data authentication;
  - Partial protection against replay attacks;
  - Data integrity;
  - Data encryption/confidentiality;

- **Compulsory/optional**:
  - It is possible to perform only encryption and then the part about authentication and integrity is optional. Or you can have authentication and integrity, and then the encryption becomes optional. But you must always have one of the two (encryption or authentication/integrity). You cannot use NULL algorithm for everything.
- **How obtain**:
  - Authentication and integrity are obtained by computing MIC, a keyed digest.
  - Confidentiality is obtained through symmetric encryption;
  - The part of no-reply is obtained thanks to the sequence number, which is embedded in the packet. It is only partial because we have only a window of protection;
- **Which part of the packet is protected**:
  - Data authentication, integrity and confidentiality applies only to the IP payload. There is no protection at all of the IP header.